

## UNIT -2

### Application Security

The two important and overlapping areas of cybersecurity are application security and network security which aims at securing data and other systematic structures. Even though both are entities with a strong focus on security they are not the same thing and address different aspects of it. Application security is the procedure of protecting software applications while network security deals with the protection of the network through which these applications can be accessed. Since cybersecurity is growing to be an important line of defence in organizations, it is crucial to distinguish between the two types of security.

### What is Application Security?

Application Security, as the name suggests, is a security program that directly deals with applications themselves. Its goal is to identify, rectify, and correct security issues in applications within an organization. It is based on identifying and fixing vulnerabilities that correspond to weaknesses or CWEs. Its testing also reveals weaknesses at the application level that help to prevent attacks.

### Advantages of Application Security

- **Protection Against Code Vulnerabilities:** Application security assists in the process of detecting and probably eradicating some of the risks that include [SQL injection](#), [cross-site scripting](#) (XSS), and buffer overflow.
- **Data Protection:** When the application is secured, all the application data that gets processed or stored is shielded from threats and breaches.
- **Compliance:** Appropriate measures for the application security in the enterprise guarantee adherence to the regulations concerning the data, for example, GDPR and HIPAA.

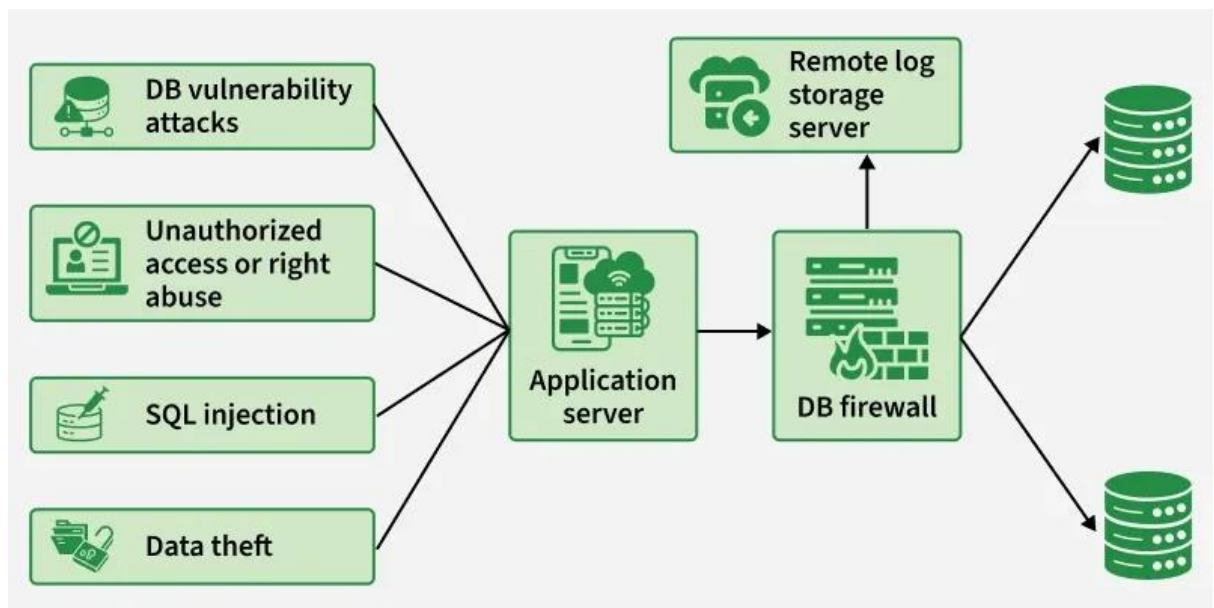
## **Disadvantages of Application Security**

- Complexity: Application often takes time and effort to secure and especially so with complex and large software systems.
- Maintenance: Constant vigil and upgrade are inevitable in the face of new threats as and when they are discovered and with change of application.
- Performance Impact: Measures like encryption and other access control measures may slow down the application as it introduces certain levels of overhead which affects the performance of the application.

## **❖ Database Security**

Database security refers to the collective measures used to protect a database management system from malicious threats and unauthorized access. In simple terms, it's making sure that only the right people can get to your data, and that the data stays accurate and available. This includes

- Use strong passwords and enforce rotation/MFA.
- Control user permissions with least privilege (grant only what's needed).
- Encrypt sensitive data at rest and in transit.
- Keep regular backups and test restores.
- Aim for CIA: confidentiality (no leaks), integrity (no tampering), availability (no downtime).



Example: Your databases hold the crown jewels—customer records, finances, credentials. If attackers slip in, you’re staring at data theft, privacy breaches, and brand damage. The diagram shows those risks (SQL injection, vuln exploits, privilege abuse, data exfiltration) hitting the app server.

To avoid a repeat of “exposed DB” wipe-and-ransom incidents, all traffic is funnelled through a DB firewall that inspects and blocks suspicious queries and enforces policy, while a remote log server captures tamper-resistant audit trails for investigation. Clean traffic proceeds to the databases.

## Common Database Attack Methods

Below are some of the most common database attack methods (from basic to advanced) and what they mean:

[SQL Injection \(SQLi\)](#) – This is the number one threat to web databases. It happens when an attacker “injects” malicious SQL code into a query (usually via a web form input) to manipulate the database. For example, they might trick your database into giving away all user data by always making a condition true. (We’ll explain an example in the next section.)

SQL injection can allow attackers to bypass logins, steal or delete data, or even take over the entire database.

**Weak Authentication & Brute-Force** – If your database accounts use default or weak passwords, attackers can simply guess or brute-force their way in. Brute-force attacks involve trying many passwords until one works. Not having account lockouts or using common passwords makes this easy for hackers.

**Privilege Abuse (Insider Threat)** – Sometimes the danger comes from legitimate users abusing their access. If a user's account has more privileges than necessary, they might misuse data. For example, a salesperson allowed to view individual customer records might run a query to export all customer data and sell it to a competitor.

**Database Misconfiguration** – An unsecured configuration can be an open door. For instance, installing a database and leaving it with default settings (default user accounts, no encryption, open network ports) is dangerous. Many cloud databases by default listen on all network interfaces and may be open to the internet if not locked down

## ❖ E -mail Security

[Email security](#) helps protect an organization's [attack surface](#) from cyber threats that use email account [attack vectors](#) such as [phishing](#) and spam to gain unauthorized access to the network. By following [email security best practices](#) for cybersecurity including email accounts, organizations can reduce the spread of [malware](#), such as [ransomware](#) and [viruses](#), to prevent successful [cyber attacks](#).

Email is a critical component of organizational communication because it enables users to communicate quickly, easily, and with a variety of devices. Further, email can be used to send a number of different types of media, and communications can be tracked,

stored, and organized according to attributes such as time and date stamps and size.

## Why Is Email Security Important?

Email security is essential due to its vital role in business communication. As the primary tool for sending and receiving sensitive information, email is vulnerable to threats and attacks. According to the [2024 Email Security Risk Report](#), 94% of organizations experienced phishing attacks in the past year, underscoring the prevalence of email-based threats. Inadequate email protection can seriously affect businesses, ranging from loss of critical data to compliance issues. Email security is vital for maintaining organizational integrity and identifying threats and potential breaches as early as possible to protect businesses

## Benefits Of Email Security

Email security provides organizations with comprehensive protection against a wide range of cyber threats, ensuring both operational continuity and data integrity. Some of the key benefits of email security include: /

1. **Protection against phishing:** Strong email security measures significantly decrease the risk of phishing attacks, which are a major threat to businesses.
2. **Increased data security:** Email security measures protect sensitive information by preventing unauthorized access and data breaches, protecting intellectual property and sensitive information.
3. **Real-time threat detection:** Advanced email security offers immediate detection and elimination, ensuring threats are handled before causing any damage.
4. **Improve compliance:** Stringent email security measures ensure confidentiality of sensitive information, and improve compliance measures to avoid any security issues.

## Types Of Email Attacks

## Phishing

A phishing attack targets users by sending them a text, direct message, or email. The attacker pretends to be a trusted individual or institution and then uses their relationship with the target to steal sensitive data like account numbers, credit card details, or login information.

Phishing comes in several forms, such as [spear phishing](#), regular phishing, and [whaling](#). Spear phishing targets a particular person, while a whaler targets someone high up in the organization by pretending to be someone they trust.

## Spoofing

Spoofing is a dangerous email threat because it involves fooling the recipient into thinking the email is coming from someone other than the apparent sender. This makes [spoofing](#) an effective [business email compromise \(BEC\)](#) tool. The email platform cannot tell a faked email from a real one because it merely reads the metadata—the same data the attacker has changed. Implementing authentication protocols like [DomainKeys Identified Mail \(DKIM\) record](#) helps verify that an email hasn't been tampered with and ensures it was actually sent from the claimed domain.

This makes the impersonation of a person the victim either knows or respects relatively easy for an attacker.

## ❖ Internet Security

Internet security refers to security designed to protect systems and the activities of employees and other users while connected to the internet, web browsers, web apps, websites, and networks.

Internet security solutions protect users and corporate assets from [cybersecurity](#) attacks and threats.

### What Are The 5 Common Internet Security Problems?

## **1. Malware**

**Malware** combines the words "malicious" and "software" and is a general term that refers to worms, viruses, Trojans, and other dangerous software that cyber criminals use to cause havoc and steal private data. Malware is any software created to harm a computer, server, or network.

## **2. Phishing**

**Phishing** is a cyberattack that uses phony emails. Hackers attempt to dupe email recipients into thinking that an attachment or link in the message is legitimate and important, such as a request from their bank or a note from a coworker. The intention is to trick individuals into providing personal information or downloading malicious software.

## **3. Botnets**

The term "botnet" comes from the word "robot network."

A **botnet** is a network of computers that have been purposefully infected with malware to help a cyber criminal automate certain actions without the consent or knowledge of the computer's owner. The same methods for infecting computers with malware—such as opening email attachments that download malware or visiting malicious websites—are typically used to infect computers with botnets. Botnets can also propagate over a network, moving from one computer to another and using these computers' computational power to execute attacks.

## **4. Spam**

Spam is a general term connoting any unwanted mail. Some spam may seem innocent, irritating at worst. But spam messages often contain malware, which can be used to infect computers, damage networks, and launch **ransomware** attacks.

Spam can also present significant problems for employees within your organization, specifically because it can clog up their email inboxes with useless, space-consuming messages. Then they have to waste time deleting hundreds or even thousands of junk emails.

## **5. Data loss**

Organizations can lose data via various means. For example, a thief can steal it or a hacker can damage a server or hard drive containing sensitive or important information.

So if a computer network is infected with ransomware, for example, completely wiping one or more computers to regain control over your assets may be necessary. If the data has no backup or if the latest backup is weeks or months old, serious operational interruptions can ensue.

## ❖ Principles of security-Confidentiality, integrity and availability

### What are examples of the CIA triad?

Here are examples of the various management practices and technologies that constitute the CIA triad. While many CIA triad cybersecurity strategies implement these technologies and practices, this list is by no means **exhaustive**.

#### Confidentiality

Sometimes safeguarding data confidentiality involves special training for those handling sensitive documents. Training can familiarize authorized people with risk factors and help them with risk assessments and to guard against those risks. Further aspects of training include strong passwords and password-related best practices, as well as information about [social engineering](#) methods bad actors use to get users to make mistakes and break data-handling rules.

A good example of a method for protecting sensitive data and ensuring confidentiality is requiring an account number or routing number when banking online. Data encryption is another common method of ensuring confidentiality. User IDs and passwords constitute a standard procedure required for social media platforms, for example. Two-factor authentication ([2FA](#)) is also becoming commonplace in the healthcare and financial services industries.



Other options include real-time [biometric verification](#), security tokens, key fobs and soft tokens. In addition, users can minimize the places where information appears and the number of times it's transmitted to complete a transaction. Extra measures might be taken in the case of extremely sensitive documents, such as storing only on [air-gapped](#) computers, on disconnected storage devices or in hard-copy form only.

## **Integrity**

Measures related to data [integrity include file permissions](#) and user access controls. Version control is used to fix instances where an authorized user makes an erroneous change or accidental deletion. Organizations usually have some means to detect changes in data that occur as a result of non-human-caused events, such as an electromagnetic pulse or server crash.

Data might include [checksums](#), even cryptographic checksums, for verification of integrity. Backups or redundancies must be available to restore the affected data to its correct state. Furthermore, digital signatures can be used to provide effective [nonrepudiation](#) measures, meaning evidence of logins, messages sent, and electronic document viewing and sending cannot be denied.

## **Availability**

Rigorously maintaining hardware, performing hardware repairs immediately and maintaining a properly functioning operating system environment free of software conflicts are the best ways to ensure availability. It's also important to keep current with all system upgrades. Providing adequate communication bandwidth and preventing bottlenecks are also important tactics. Redundancy, failover, redundant array of independent disks ([RAID](#)) and even [high availability](#) clusters can mitigate serious consequences when hardware issues do occur.

Fast, adaptive disaster recovery (DR) plans are essential for the worst-case scenarios and require a comprehensive approach. Safeguards against data loss or interruptions in connections must include unpredictable events,

such as power outages, natural disasters and fire. To prevent data loss from such occurrences, backup copies can be stored in a geographically isolated location or fireproof, waterproof safe. Extra security equipment and software, such as firewalls and proxy servers, can guard against downtime. They also help prevent security incidents that result in unreachable data blocked by malicious [denial-of-service attacks](#), ransomware and other malware or cyber-attacks.

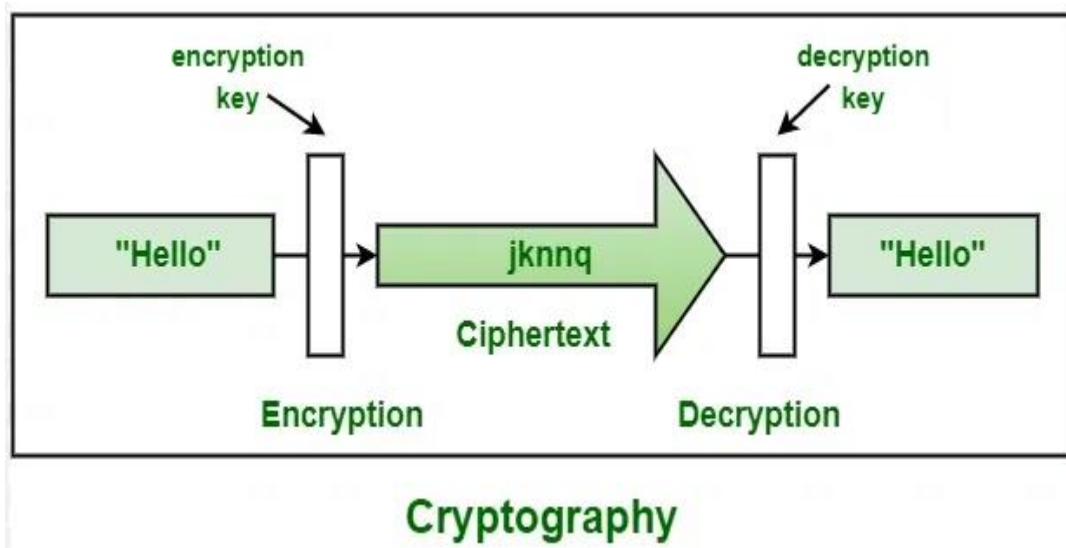
## ❖ Cryptography and its Types

Cryptography is the science of protecting information using mathematical techniques to ensure confidentiality, integrity, and authentication. It transforms readable data into unreadable form, preventing unauthorized access and tampering.

- Converts plaintext into ciphertext using algorithms and keys
- Ensures confidentiality, integrity, authentication, and non-repudiation
- Used in secure communication, digital signatures, passwords, and online transactions

### Working of Cryptography

As we all know that cryptography technique is use to convert plain text into ciphertext. This technique is done by cryptographic key. Basically, cryptographic key is a string of characters which is used to encrypts the data and decrypt the data.



- **Plaintext is created**  
The original readable message or data.
- **A cryptographic algorithm is chosen**  
Example: AES, RSA, SHA-256, etc.
- **A key is applied**  
This key controls how the encryption or hashing is performed.
- **Encryption converts plaintext → ciphertext**  
The data becomes unreadable to unauthorized users.
- **Ciphertext is transmitted or stored securely**  
Even if intercepted, it cannot be understood without the correct key.
- **Decryption converts ciphertext → plaintext**  
The receiver uses the correct key (same key for symmetric, different for asymmetric).
- **Integrity checks may be used**  
Hashing ensures the message has not been altered.

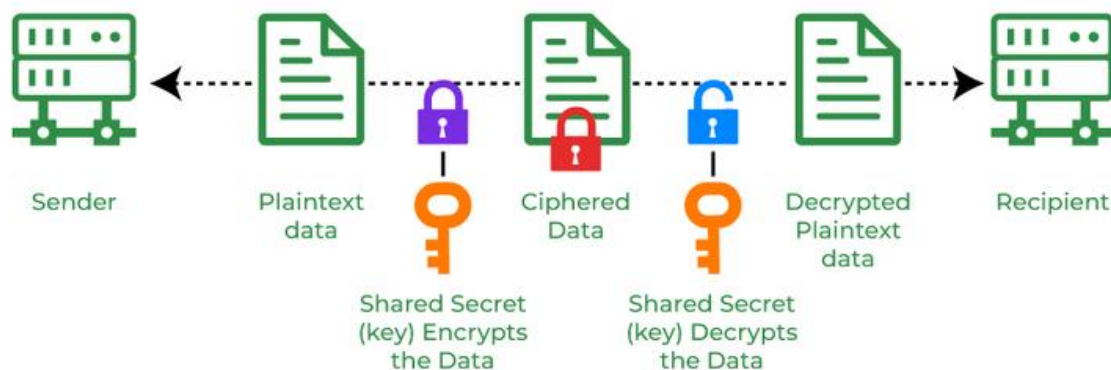
## Types Of Cryptography

There are three types of cryptography, namely Symmetric Key Cryptography, Asymmetric Key Cryptography and Hash functions, here's a detailed explanation below:

### 1. Symmetric Key Cryptography

Symmetric Key Cryptography is an encryption system where the sender and receiver of a message use a single common key to encrypt and decrypt messages.

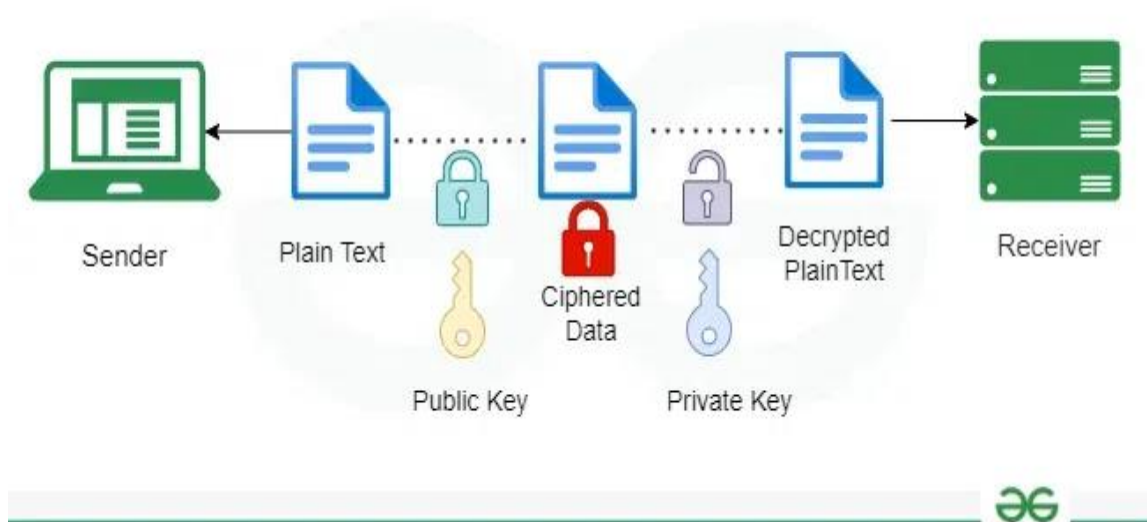
- Symmetric Key cryptography is faster and simpler but the problem is that the sender and receiver have to somehow exchange keys securely.
- The most popular symmetric key cryptography systems are Data Encryption Systems (DES) and Advanced Encryption Systems (AES) .



### 2. Asymmetric Key Cryptography

In Asymmetric Key Cryptography a pair of keys is used to encrypt and decrypt information. A sender's public key is used for encryption and a receiver's private key is used for decryption. Public keys and Private keys are different. Even if the public key is known by everyone the

intended receiver can only decode it because he holds his private key. The most popular asymmetric key cryptography algorithm is the RSA algorithm.



## ❖ Message Authentication

Data is prone to various attacks. One of these attacks includes message authentication. This threat arises when the user does not have any information about the originator of the message. Message authentication can be achieved using cryptographic methods which further make use of keys.

### Authentication Requirements:

- **Revelation:** It means releasing the content of the message to someone who does not have an appropriate cryptographic key.
- **Analysis of Traffic:** Determination of the pattern of traffic through the duration of connection and frequency of connections between different parties.

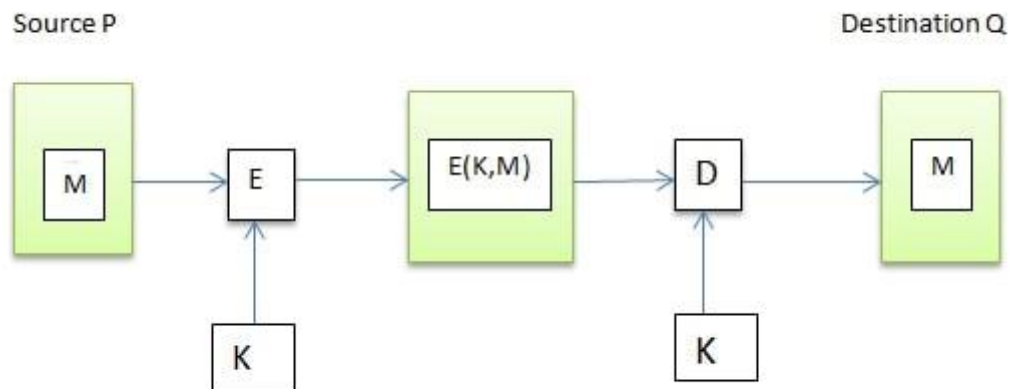
- **Deception:** Adding out of context messages from a fraudulent source into a communication network. This will lead to mistrust between the parties communicating and may also cause loss of critical data.
- **Modification in the Content:** Changing the content of a message. This includes inserting new information or deleting/changing the existing one.
- **Modification in the sequence:** Changing the order of messages between parties. This includes insertion, deletion, and reordering of messages.
- **Modification in the Timings:** This includes replay and delay of messages sent between different parties. This way session tracking is also disrupted.
- **Source Refusal:** When the source denies being the originator of a message.
- **Destination refusal:** When the receiver of the message denies the reception.

Message Authentication Functions:

All message authentication and digital signature mechanisms are based on two functionality levels:

- **Lower level:** At this level, there is a need for a function that produces an authenticator, which is the value that will further help in the authentication of a message.
  - **Higher-level:** The lower-level function is used here in order to help receivers verify the authenticity of messages.
- 
- **Message encryption:** While sending data over the internet, there is always a risk of a Man in the middle(MITM) attack. A possible solution for this is to use message encryption. In message encryption, the data is first converted to a ciphertext and then sent any further. Message encryption can be done in two ways:
  - **Symmetric Encryption:** Say we have to send the message M from a source P to destination Q. This message M can be encrypted using a secret key K that both P and Q share. Without this key K, no other person can get the plain text from the

ciphertext. This maintains confidentiality. Further, Q can be sure that P has sent the message. This is because other than Q, P is the only party who possesses the key K and thus the ciphertext can be decrypted only by Q and no one else. This maintains authenticity. At a very basic level, symmetric encryption looks like this:



## ❖ Application of Cryptography

### Applications of Cryptography

Cryptography ensures messages are safe when people send them, and it's used in many different areas. Here are some notable applications:

- **Secure Communication:** Cryptography is widely used to secure communication channels, such as emails, instant messaging, and voice-over-IP (VoIP) calls. Encrypting the transmitted data prevents eavesdropping and ensures the confidentiality and integrity of the information exchanged.
- **Data Protection:** It is vital in safeguarding sensitive data stored on computers, servers, and other digital devices. It encrypts files, directories, and entire storage volumes, thereby preventing unauthorized access and data breaches.

- **Online Transactions:** In e-commerce and online banking, cryptography is employed to secure transactions conducted over the Internet. It enables the encryption of financial data, including credit card details and banking credentials, protecting them from interception by cybercriminals.
- **Authentication and Digital Signatures:** Cryptography facilitates authentication and verification mechanisms, allowing users to prove their identity and verify the integrity of digital documents. Digital signatures, created using cryptographic techniques, provide non-repudiation and ensure that the signer cannot deny their involvement in the transaction.

*Our Learners Also Read: Top 10 [Cyber Security Threats](#) You Should Be Aware*

Features of Cryptography

Cryptography makes sure that information stays private, unchanged, and genuine, and it prevents people from denying their actions. Last of all, some key features of cryptography include:

- **Confidentiality:** Cryptography hides information so only people with the right key can read it.
- **Integrity:** It helps make sure data doesn't change when it's sent or stored. As well as special tools can spot if someone tries to change it.
- **Authentication:** It helps in checking who's involved in messages or deals. Using things like digital signatures and special systems for proving identities.
- **Non-repudiation:** It stops people from saying they didn't do something. Like sending a message, using special marks to prove who sent it.
- **Access control:** It helps keep secret stuff safe by only letting certain people with special keys get to it.

## ❖ Security Technology firewall and its types



A network firewall is a security system that protects private networks from unauthorized access. It monitors and controls incoming and outgoing traffic based on predefined security rules.

- Acts as a barrier between internal (trusted) and external (untrusted) networks
- Can be hardware-based, software-based, or both
- Filters traffic using rules, policies, and inspection methods
- Main goal: prevent attacks, malware, and unauthorized access

## **Types**

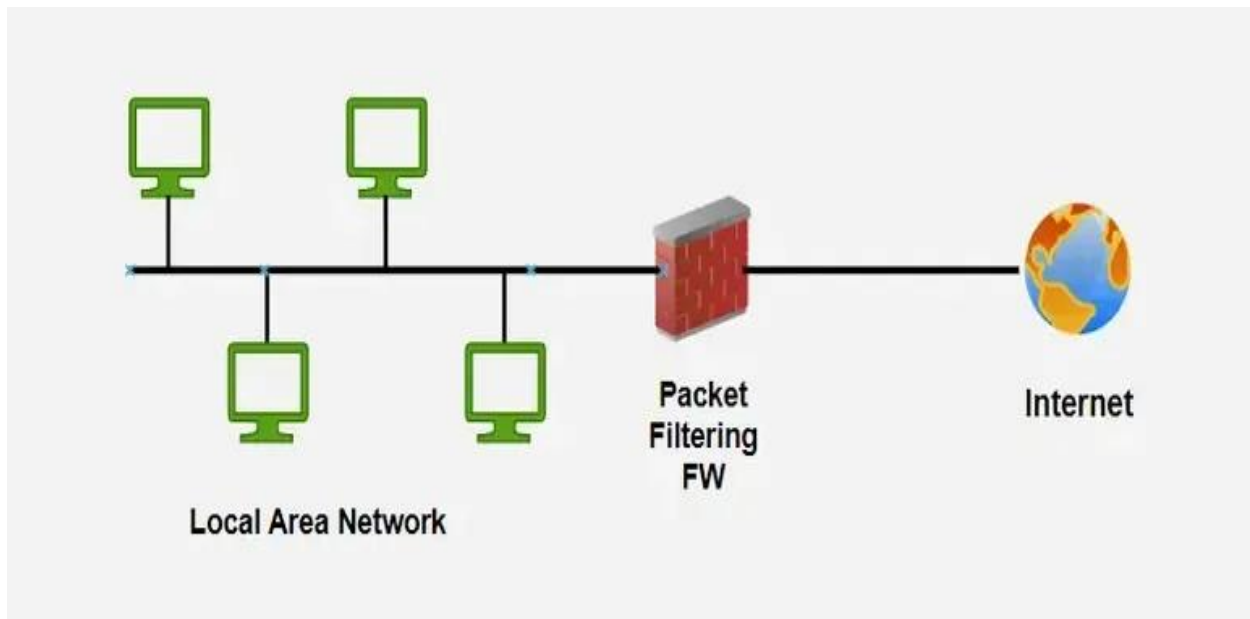
### **Based on Function (How They Filter Traffic)**

Network Security is the process of protecting networks, systems, and data from unauthorized access, attacks, and damage.

#### **a. Packet Filtering Firewall**

A basic firewall that checks packet headers like IP, port, and protocol.

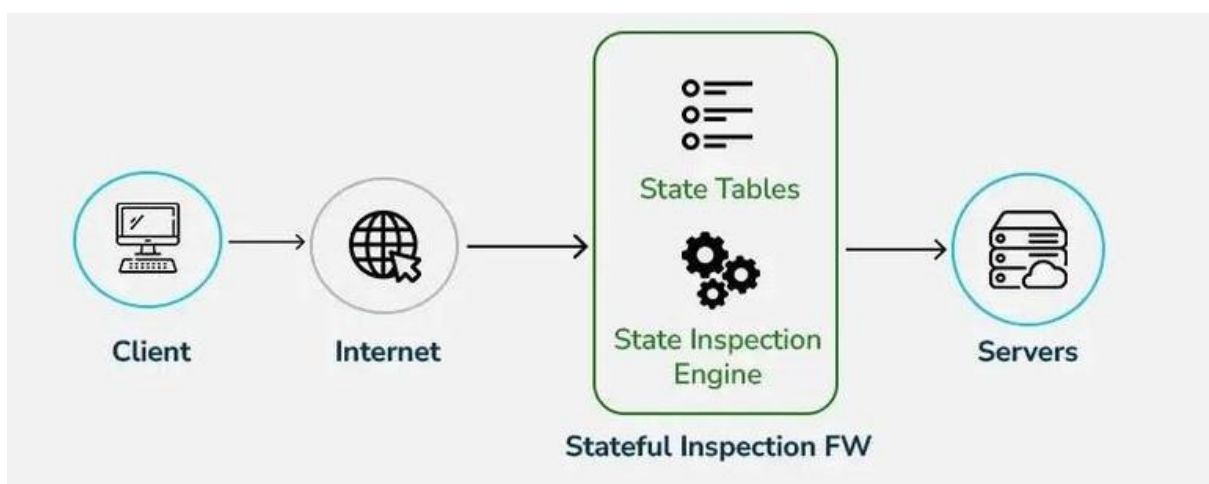
- Very fast and lightweight
- Does not inspect data inside packets
- Provides basic security only



## b. Stateful Inspection Firewall

Tracks active connections and makes decisions based on traffic context.

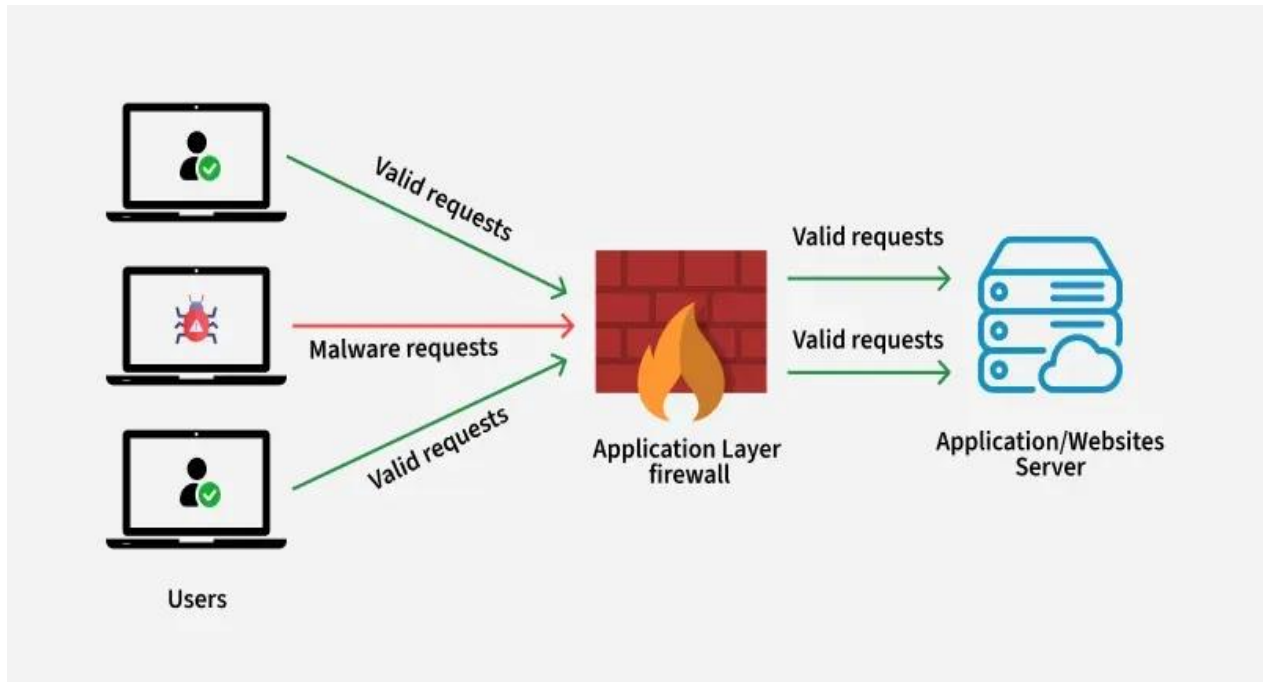
- More secure than packet filtering
- Remembers past traffic (state table)
- Blocks suspicious or unexpected packets



## c. Proxy (Application-Level) Firewall

Acts as a middleman between user and destination server.

- Filters data at the application layer
- Hides internal network details
- Can block malicious content before it reaches the user



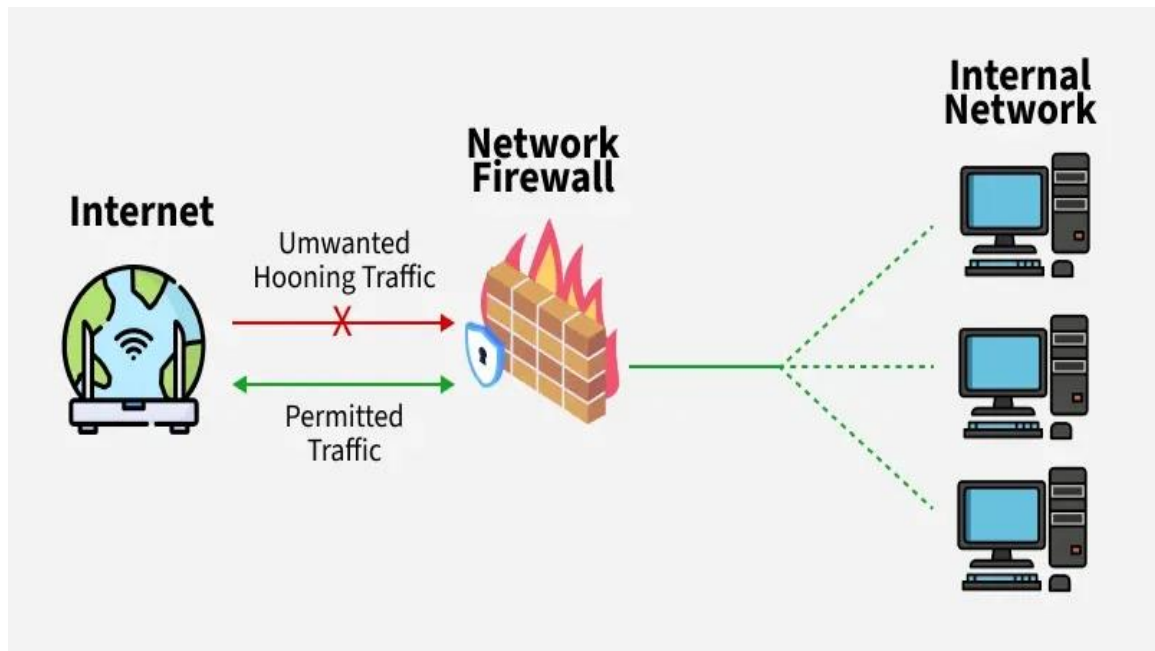
## 2) Network Firewall

A Network Firewall secures the perimeter, while a host-based firewall protects the endpoint.

### a. Network Firewall

Placed at the network perimeter to protect the whole network.

- Controls inbound & outbound traffic
- First line of defense
- Ideal for organizations



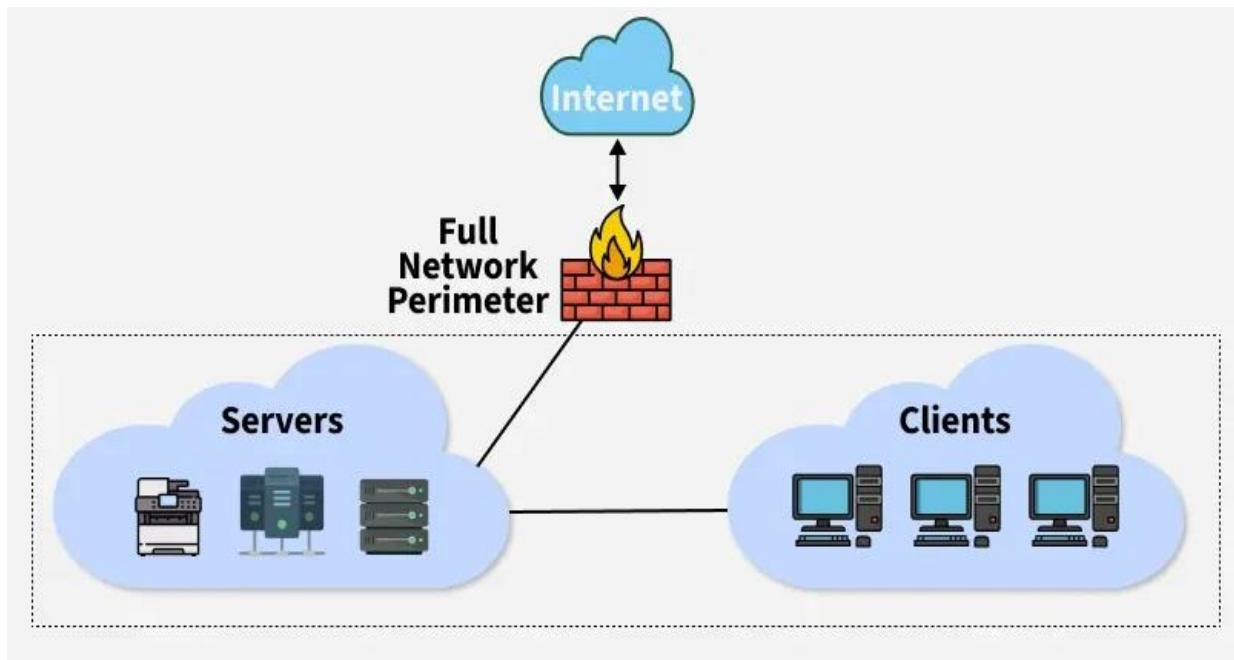
### 3) Data Filtering Method

All three of these firewall types work to control network access, but they differ in their placement and scope.

#### a. Perimeter Firewall

Placed at the edge to filter traffic between internet and internal network.

- Central security control
- Blocks external attacks
- Common in corporate environments



## ❖ Firewall benefit

Firewalls are essential network security systems that protect digital assets by monitoring, filtering, and blocking unauthorized traffic and malicious software based on defined security rules. Key benefits include preventing malware attacks, securing sensitive data from hackers, enforcing user access control, and improving overall network performance.

Palo Alto Networks +3

### **Key Benefits of a Firewall:**

- **Network Security:** Firewalls block malicious software and unauthorized access to internal networks, securing sensitive data from attacks.
- **Traffic Monitoring & Filtering:** They inspect incoming and outgoing traffic (packets) against security rules, stopping threats like viruses and unauthorized access points.
- **Preventing Malware Attacks:** They prevent spyware and viruses from installing, protecting the system from harmful programs.

- **Data Privacy & Compliance:** Firewalls protect sensitive client and employee data, fostering trust, and help businesses meet regulatory compliance requirements for network security.
- **Network Segmentation:** They enable the segmentation of network resources, which limits how far an attacker can move if one area is compromised.
- **Controlled Access:** Firewalls allow administrators to define specific rules for who can access certain networks, increasing control over IT infrastructure.
- **Enhanced Performance:** By blocking unnecessary or malicious traffic, firewalls prevent network congestion and improve overall system stability.

#### **Types of Firewalls:**

- **Hardware Firewalls:** Dedicated hardware that protects an entire network, often placed between a router and a network.
- **Software Firewalls:** Installed on individual computers to monitor traffic for that specific device.
- **DNS Firewalls:** Protect against malicious websites and prevent users from visiting potentially dangerous sites.

## **❖ Virtual Private Network - VPN**

A Virtual Private Network (VPN) is a security technology that creates an encrypted tunnel between your device and a VPN server over the internet, so your traffic travels privately and your real IP address is hidden.

- **Privacy protection:** Hides your IP and encrypts traffic, so ISPs, advertisers, and third parties can't easily monitor your browsing.
- **Security on public Wi-Fi:** Encryption protects logins and personal data on unsafe networks (airports, cafes).

- **Bypass geo-restrictions:** Changes your apparent location by routing through another region's server, unlocking region-limited sites or services.
- **Reduce ISP throttling:** Since traffic is encrypted, ISPs can't easily identify specific activities (streaming/gaming) to selectively slow them.
- **Secure remote access:** Let employees connect to internal company resources securely from outside the organization.

## Working

1. **Connection establishment:** When you turn on the VPN, the VPN client authenticates you and sets up a secure session with a VPN server.
2. **Data encryption:** Your outgoing traffic is encrypted using cryptographic algorithms, so intercepted packets look like unreadable ciphertext to hackers, ISPs, or attackers on public Wi-Fi.
3. **Traffic redirection (tunnelling):** The encrypted traffic is sent through the tunnel to the VPN server, and the VPN server replaces your real IP with its own public IP, hiding your identity/location from the destination site.
4. **Decryption and forwarding:** The VPN server decrypts the traffic and forwards it to the actual website/service; replies come back to the VPN server and then travel back to you through the same encrypted tunnel.
5. **End-to-end protection:** This tunnel provides privacy (confidentiality), helps maintain integrity against tampering during transit, and improves anonymity by masking your IP

## ❖ Antivirus Software

### What is Antivirus Software?

Antivirus software (computer protection software) is a program(s) that is created to search, detect, prevent and remove [software viruses](#) from your system that can harm your system. Other

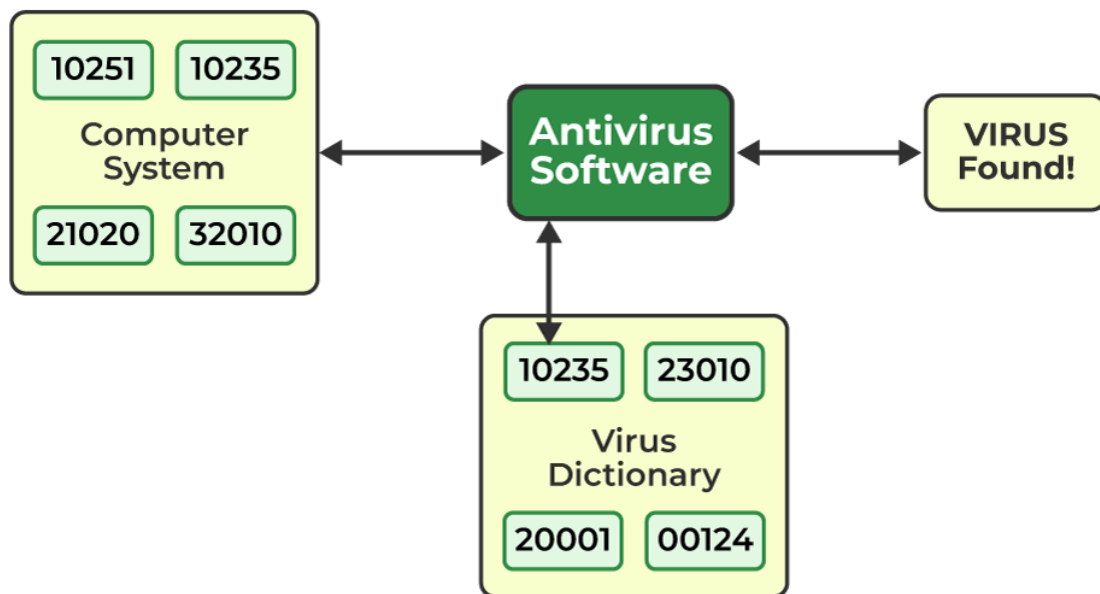
harmful software such as [worms](#), [adware](#), and other [threats](#) can also be detected and removed via antivirus. This software is designed to be used as a proactive approach to [cyber security](#), preventing threats from entering your computer and causing issues. Most antivirus software operates in the background once installed, providing real-time protection against virus attacks.

While you may believe that your computer is safe as long as you don't visit questionable [websites](#), hackers have far more sophisticated methods of infecting your computer, which is why you need a powerful antivirus to stay to secure your [data](#) and system. The implications of a virus getting into your computer might be fatal. Viruses can cause a wide range of malicious behaviour. They can crash your device, monitor your accounts, or spy on you through your [webcam](#). So, always use antivirus software.

## **How Antivirus Works?**

Antivirus software works by comparing your [computer applications](#) and files to a [database](#) of known malware kinds. Because hackers are continually creating and disseminating new viruses, they will also check systems for the presence of new or undiscovered malware threats. The antivirus checks files, programs, and applications going in and out of your computer to its database to identify matches. Similar and identical matches to the database are segregated, scanned, and eliminated.





### How Antivirus Works?

Most Antivirus programs will employ these four types of detection techniques:

- **Signature detection** is a method by which an antivirus keenly scans files that are brought into a system to analyze more likely hazardous files.
- **Specific detection**, which looks for known parts or types of malware or patterns that are linked by a common codebase
- **A generic the detection** is a type of detection that looks for known parts or types of malware or patterns that are related to a common codebase.
- **Heuristic detection** is a type of virus detection that looks for unknown infections by spotting suspicious file structures.